

Contents

1	DD02: 4-eyes 承認フロー (運営者システム)	1
1.1	0. 文書情報	1
1.2	1. 対象範囲	1
1.3	2. 収録ロジック・対応章	1
1.4	3. 詳細設計本文	2
1.4.1	3.1 4-eyes 対象 10 操作	2
1.4.2	3.2 状態遷移 (operator_approvals.state)	2
1.4.3	3.3 payload_hash 検証	2
1.4.4	3.4 自己承認禁止	3
1.4.5	3.5 4-eyes 申請モデル (CMP-E、★TH-5)	3
1.4.6	3.6 4-eyes 承認モデル (CMP-F、★TH-5)	3
1.4.7	3.7 4-eyes API OpenAPI 抜粋	4
1.4.8	3.8 楽観ロック・同時実行制御	6
1.4.9	3.9 期限切れ自動バッチ	6
1.4.10	3.10 4-eyes フロー E2E テストシナリオ (付録 C.X)	6
1.5	4. 関連設計	6
1.6	5. テスト観点	7
1.6.1	5.1 ユニットテスト	7
1.6.2	5.2 結合テスト (Miniflare)	7
1.6.3	5.3 E2E テスト (Playwright)	7
1.6.4	5.4 負荷試験	7
1.6.5	5.5 受入条件マッピング	7
1.7	6. 未確定事項・確認事項	7

1 DD02: 4-eyes 承認フロー (運営者システム)

1.1 0. 文書情報

項目	内容
文書名	DD02: 4-eyes 承認フロー (運営者システム)
詳細設計 ID	DD02
対象システム	FAQ AI ウィジェット SaaS / 運営者システム
関連機能 ID	FR-226, D-12
作成日	2026-05-17
版数	v1.0
ステータス	承認済

1.2 1. 対象範囲

種別	ID	名称
機能	FR-226	4-eyes 申請承認 (MVP 3 ハードゲート + 7 承認ログ)
画面	SCR-APPROVALS	承認待ち一覧
画面	SCR-APPROVALS-M1	申請モデル (CMP-E)
画面	SCR-APPROVALS-M2	承認モデル (CMP-F)
API	POST /approvals	申請作成
API	POST /approvals/{id}/start-review	レビュー開始
API	POST /approvals/{id}/approve	承認
API	POST /approvals/{id}/reject	却下
API	POST /approvals/{id}/withdraw	自己取下げ
API	POST /approvals/{id}/execute	実行
テーブル	operator_approvals	申請・承認状態管理

1.3 2. 収録ロジック・対応章

元章	元タイトル	概要
§ 5 SCR-APPROVALS	画面詳細 (参照)	承認待ち一覧 + 申請モジュール + 承認モジュール
§ 6.4	4-eyes 機能詳細	申請 → 承認 → 実行のロジック
§ 7.4	4-eyes API	OpenAPI(申請 / start-review / approve / reject / withdraw)
付録 C.X	4-eyes フロー E2E テストシナリオ	5 シナリオ (happy / self-block / expire / rollback / hash)
付録 E	4-eyes 操作詳細 (MVP)	対象 10 操作 + 申請/承認モジュール ASCII レイアウト

1.4 3. 詳細設計本文

1.4.1 3.1 4-eyes 対象 10 操作

#	action_code	MVP ハードゲート	MVP 承認ログ
1	owner.physical_delete	必須	-
2	ai_parameter.update	必須	-
3	master_key.rotate	必須	-
4	owner.suspend	-	単独 + 事後監査
5	owner.restore	-	対象
6	pricing.update	-	対象
7	rate_limit.override / budget_limit.override	-	対象
8	widget.force_stop	-	対象
9	feature.hard_gate.toggle	-	対象
10	owner.restore_data(FR-204、削除データ復元)	-	対象

ハードゲート 3 操作は **X-Approval-Id** ヘッダ必須 + 承認済 (**approved** 状態) 申請に紐付かない限り **403 FORBIDDEN_HARD_GATE** を返す。承認ログのみ 7 操作は単独実行可能だが、**audit_logs** 上に必ず 1 件の **operator_approval.*** 履歴を残す。

1.4.2 3.2 状態遷移 (operator_approvals.state)

From	To	トリガー	ガード
-	requested	POST /approvals	expires_at = +72h
requested	reviewing	start-review	requested_by ≠ reviewer
reviewing	approved	approve	DB CHECK 自己承認禁止
reviewing	rejected	reject	requested_by ≠ rejected_by、コメント必須
requested	withdrawn	withdraw(申請者本人)	withdrawn_by == requested_by(自己取下げ)
requested/reviewing	expired	72h 経過	バッチ
approved	executed	execute	now < approved_at + 72h、payload_hash 一致
approved	expired	72h 経過	バッチ

詳細状態遷移は [DD11_状態遷移詳細.md](#) § B.3 を参照。

1.4.3 3.3 payload_hash 検証

項目	仕様
計算式	sha256(canonical_json(payload))(RFC 8785 JSON Canonicalization)
申請時	申請者送信の payload を正規化し、operator_approvals.payload_hash に保管
承認時	承認者が確認した payloadHash を送信 (改ざん検知用)、DB 値と一致しなければ 409
実行時	実行 API 呼出時の payload を再正規化し、operator_approvals.payload_hash と一致確認。不一致なら 403

payload_hash 不一致は承認 → 実行間で **payload** を改ざんしようとする攻撃を検出する仕組み。承認モジュールでは **payload_hash: sha256:...(検証 OK)** を表示する。

1.4.4 3.4 自己承認禁止

実装層を4重で防御する:

1. **アプリケーション層**: start-review/approve で requestedBy === currentOperator を拒否(403)
2. **DB CHECK 制約**: CHECK (requested_by != approved_by) を operator_approvals テーブルに付与
3. **監査チェック**: 監査ログ集計で同一運営者の request + approve ペアを検出する日次バッチ
4. **承認モジュール UI ガード**: SelfApprovalGuard コンポーネントでボタン無効化

1.4.5 3.5 4-eyes 申請モジュール (CMP-E、★TH-5)

★ 申請モジュール: AI 推論パラメータ更新	
action_code: ai_parameter.update 申請者: 田中 (現在ログイン中)	
申請理由 [必須、最大 1000 文字]	
対応チケット ID [必須、最大 64 文字]	
TKT-	
payload プレビュー (編集不可、整形済 JSON)	
<pre>{ "scope": "owner", "scopeId": "01J9...", "confidenceThreshold": 0.65, ... }</pre>	
payload_hash: sha256:abc123def...	
承認 TTL: 72 時間	
[キャンセル]	[申請する] →

1.4.6 3.6 4-eyes 承認モジュール (CMP-F、★TH-5)

★ 承認モジュール: AI 推論パラメータ更新	
申請者: 田中 (2026-05-12 10:00)	
あなた: 佐藤 (承認者)	
申請 ID: 01J9V0...	
申請から: 1 時間 15 分前	
期限: 70 時間 45 分後	
申請理由:	
契約 acme 向け関連度しきい値を緩和 #TKT-1234	
payload プレビュー (整形済 JSON、改ざんチェック済):	

<pre>{ "scope": "owner", "scopeId": "01J9...", "confidenceThreshold": 0.65, ... }</pre>
payload_hash: sha256:abc123def...(検証 OK)
コメント [任意]
[保留] [却下 (コメント必須)] [承認]

1.4.7 3.7 4-eyes API OpenAPI 抜粋

```
paths:
  /approvals:
    post:
      summary: 4-eyes 申請作成
      parameters:
        - $ref: "#/components/parameters/XOpTicketId"
        - $ref: "#/components/parameters/IdempotencyKey"
        - $ref: "#/components/parameters/XCsrftoken"
      requestBody:
        required: true
        content:
          application/json:
            schema:
              type: object
              required: [actionCode, payload, reason]
              properties:
                actionCode: { type: string }
                payload: { type: object }
                reason: { type: string, maxLength: 1000 }
      responses:
        "201":
          description: 申請完了
          content:
            application/json:
              schema:
                type: object
                properties:
                  approvalId: { type: string }
                  expiresAt: { type: string, format: date-time }
                  payloadHash: { type: string }
        "409":
          content:
            application/problem+json:
              schema: { $ref: "#/components/schemas/Problem" }

  /approvals/{id}/start-review:
    post:
      summary: 4-eyes 承認確認開始
      parameters:
        - in: path
          name: id
```

```

        required: true
        schema: { type: string }
    - $ref: "#/components/parameters/XOpTicketId"
    - $ref: "#/components/parameters/IdempotencyKey"
responses:
  "200": { description: reviewing 遷移完了 }
  "403":
    content: { application/problem+json: { schema: { $ref: "#/components/schemas/Problem" } } }

/approvals/{id}/approve:
  post:
    summary: 4-eyes 承認
    parameters:
      - in: path
        name: id
        required: true
        schema: { type: string }
      - $ref: "#/components/parameters/XOpTicketId"
      - $ref: "#/components/parameters/IdempotencyKey"
      - $ref: "#/components/parameters/XCsrfToken"
    requestBody:
      required: true
      content:
        application/json:
          schema:
            type: object
            required: [payloadHash]
            properties:
              payloadHash: { type: string }
              comment: { type: string }
    responses:
      "200": { description: approved 遷移完了 }
      "403":
        content: { application/problem+json: { schema: { $ref: "#/components/schemas/Problem" } } }

/approvals/{id}/reject:
  post:
    summary: 4-eyes 却下 (別運営者)
    parameters:
      - in: path
        name: id
        required: true
        schema: { type: string }
      - $ref: "#/components/parameters/XOpTicketId"
    requestBody:
      required: true
      content:
        application/json:
          schema:
            type: object
            required: [comment]
            properties:
              comment: { type: string }
    responses:
      "200": { description: rejected 遷移完了 }
      "403":
        content: { application/problem+json: { schema: { $ref: "#/components/schemas/Problem" } } }

/approvals/{id}/withdraw:
  post:
    summary: 4-eyes 自己取下げ (申請者本人)
    parameters:

```

```

- in: path
  name: id
  required: true
  schema: { type: string }
- $ref: "#/components/parameters/XOpTicketId"
responses:
  "200": { description: withdrawn 遷移完了 }
  "403":
    content: { application/problem+json: { schema: { $ref: "#/components/schemas/Problem" } } }
  "409":
    content: { application/problem+json: { schema: { $ref: "#/components/schemas/Problem" } } }

```

完全な API スキーマは [基本設計 / API 設計](#) §4 を正本とする。

1.4.8 3.8 楽観ロック・同時実行制御

- `operator_approvals` テーブルに `version` 列 (INTEGER、初期値 0) を保持
- 状態遷移 UPDATE は `WHERE id=? AND version=?` で実行し、`version = version + 1` を SET
- 競合 (同時に 2 名が承認ボタン押下) は影響行数 = 0 で検出、後勝ちを 409 で拒否
- 負荷試験 A4(100 申請を 10 秒で集中、別運営者 100 並列承認) で楽観ロック動作を検証

1.4.9 3.9 期限切れ自動バッチ

72 時間経過で `requested` / `reviewing` / `approved` 状態を一斉 `expired` に遷移させる:

```

function approvalExpiry():
  candidates = D1.query("SELECT id, state FROM operator_approvals
                        WHERE state IN ('requested','reviewing','approved')
                        AND expires_at <= ?", now)
  for c in candidates:
    D1.exec("UPDATE operator_approvals
            SET state='expired', expired_at=?, version=version+1
            WHERE id=? AND state=?", now, c.id, c.state)
    audit_logs(operator_approval.expire, 5y, payload={approvalId: c.id})

```

バッチは 1 時間ごとに別 cron Worker (または `AnnouncementSchedulerWorker` 内のサブタスク) で実行する。

1.4.10 3.10 4-eyes フロー E2E テストシナリオ (付録 C.X)

申請 → 承認 → 実行 → 失敗ロールバックの完全フロー E2E を別途定義し、SCR 個別 E2E と分離管理する:

シナリオ ID	内容	対象 action_code 例	テストファイル
e2e-4eyes-happy-001	正常: 申請 → start_review → 承認 → 実行 → 監査ログ 4 件記録	ai_parameter.update	apps/admin-console/e2e/4eyes/happy-path.spec.ts
e2e-4eyes-self-block-001	自己承認拒否: requester==approver で 403	ai_parameter.update	apps/admin-console/e2e/4eyes/self-approve-block.spec.ts
e2e-4eyes-expire-001	72h 期限切れ自動 expire	owner.physical_update	apps/admin-console/e2e/4eyes/expire-flow.spec.ts
e2e-4eyes-rollback-001	実行失敗 → ロールバック → 監査ログ execute_failed 記録	owner.restore	apps/admin-console/e2e/4eyes/execute-failure-rollback.spec.ts
e2e-4eyes-hash-001	payload_hash 改ざん検出 (承認時に Hash 不一致で却下)	master_key.rotate	apps/admin-console/e2e/4eyes/payload-tampering.spec.ts

1.5 4. 関連設計

種別	参照先
要件	../01_ 要件定義/index.md
基本設計	../02_ 基本設計/index.md
API 設計 (正本)	../02_ 基本設計/02_API 設計.md
画面設計 (正本)	../02_ 基本設計/01_ 画面設計.md
認証・認可設計 (正本)	../02_ 基本設計/08_ 認証・認可設計.md
関連 DD	DD01_ 運営者認証・6 段認可.md / DD03_ 監査ハッシュチェーン.md / DD11_ 状態遷移詳細.md
運用設計	../04_ 運用設計/index.md
将来対応	../05_future/index.md

1.6 5. テスト観点

1.6.1 5.1 ユニットテスト

- `payload_hash` 計算 (RFC 8785 canonical_json + sha256)
- 自己承認禁止 (アプリケーション層)
- 状態遷移ガード (`requested` → `reviewing` → `approved` → `executed` のみ正常パス、その他は遷移不可)
- 楽観ロック競合検出 (影響行数 = 0)

1.6.2 5.2 結合テスト (Miniflare)

- 申請 → 承認 → 実行の完全パスで監査ログ 4 件 (`request` / `start_review` / `approve` / `execute`) が記録される
- 自己承認試行で 403 + 監査ログ未記録
- 72h 経過 expiry バッチで `expired` 遷移 + 監査記録
- `payload_hash` 不一致での承認・実行拒否

1.6.3 5.3 E2E テスト (Playwright)

付録 C.X の 5 シナリオすべて。

1.6.4 5.4 負荷試験

シナリオ	構成	合格基準
(A3) 4-eyes 承認バースト	同時申請 50 件 / 承認 50 件	楽観ロック・状態遷移整合性、レース条件で重複承認 = 0 件
(A4) 4-eyes 同時申請	100 申請を 10 秒で集中、別運営者から 100 並列承認	レース条件で重複承認 = 0 件、申請 → 承認 → 実行が単調進行

1.6.5 5.5 受入条件マッピング

AC	検証手段
AC-038(運営者操作監査 + 通知)	E2E + 月次監査 (関連)

1.7 6. 未確定事項・確認事項

確認事項 ID	確認内容	優先度	ステータス
-	v1.0 リリース時点で全項目確定済み	低	確認済